

APC by Schneider Electric Firmware Attack Surface & Detection Brief

Scope: ~5 product lines (NMC2 AP9630/9631/9635, NMC3 AP9640/9641/9643, Rack PDU 2G AP86xx, NMC1 AP9617/9618/9619, Smart-UPS SRT/SRTL/SMT/SMC/SMX/XU/XP family) / 20,859 unique hashes across 5 architecture classes (plus a 6th Power Infrastructure / L0-L1-adjacent class for the Smart-UPS internal MCU). Findings combine CVE/PSIRT research and direct examination of the extracted NMC firmware (catalog inventory, signed-image headers, embedded web UI strings) plus the full Smart-UPS Wizard payload extraction. APC management cards are *not* large-rootfs Linux devices — they are compact firmware blobs (proprietary RTOS / embedded Linux derivative) with an embedded web/SSH/SNMP stack; the Smart-UPS internal MCU is a bare-metal Cadillac/CBL chipset reached only via the NMC or USB/serial.

Known coverage gap — Smart-UPS internal MCU firmware (Smart-UPS / SRT / SRTL / SMT / SMC / SMX / XU / XP family). This gap is **now closed** via Group F's 20,369-row Smart-UPS Wizard extraction. The UPS controller firmware running on the Smart-UPS Online SRT board (SRT5KRMXLI, SRT5KXLT, SRT5KRMXLT30, SRT3000RMXLI, SRT8KXLI, SRT10KXLI, the SRTL Li-Ion line, SMT1500RM2UC, SMC1500, and the SMX/XU/XP series) is now catalogued as Group F — directly analogous to [Eaton brief Group D](#) (bare-metal UPS MCU `.sta` family). This matters because **CVE-2022-0715 — the third TLStorm CVE — targets the Smart-UPS internal firmware specifically, not the NMC:** it's the signature-check bypass on the firmware-upgrade path. Groups A and B reference it as the persistence anchor for the TLStorm chain, and the brief now has 20,369 Smart-UPS Wizard hashes to match a Smart-UPS internal firmware image against. Pre-fix payloads ship raw `.bin`; post-fix payloads ship as `.enc` signed format. See [the Smart-UPS-Online-SRT staging README](#) for download pointers and extraction notes.

Purdue layer mapping: NMC1/NMC2/NMC3/Rack PDU 2G live at **Purdue L3.5 (IT/OT Boundary)** as the SNMP+web bridge from corporate IT to OT power infrastructure; PowerChute / EcoStruxure IT runs at **Purdue L3 (Site Operations)**; the Smart-UPS internal MCU (Group F) sits at the **Power Infrastructure** cross-cut (L0/L1-adjacent, no IP network surface on the UPS itself). See [purdue-l35-it-ot-boundary-brief.md](#) (includes the Power Infrastructure appendix) and [purdue-l3-site-operations-brief.md](#) for the cross-vendor views of those layers.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A. NMC3 (modern)	L3.5 IT/OT Boundary	AP9640, AP9641, AP9643	Signed firmware (ECDSA), embedded HTTPS/SSHv2/SNMPv3 web UI, "Trusted Platform" boot	82 hashes
B. NMC2 (legacy)	L3.5 IT/OT Boundary	AP9630, AP9631, AP9635	Older APC web/SSH stack (Mocana NanoSSL), TLStorm-vulnerable lineage, no enforced signing pre-6.8	85 hashes
C. Rack PDU 2G NMC	L3.5 IT/OT Boundary (with L1 outlet-actuation control plane)	AP86xx Switched / Metered switched (AP8941, AP8959, AP8861, AP8865 etc.)	NMC variant with outlet-control firmware path; HTTPS/SSH/SNMPv3 + per-outlet control plane	71 hashes
D. Windows-side	L3 Site Operations (PCNS server); L4 corp-IT (PowerChute Personal/Business on user PCs); L3↔L4/L5 (EcoStruxure IT Expert cloud)	PowerChute Network Shutdown (PCNS), PowerChute Business / Personal, PowerChute Serial Shutdown (PCSS), EcoStruxure IT Gateway / Expert	Java + Windows service stack the admin runs; reaches NMC via HTTPS/SNMP	4,083 rows (PCSS)
E. NMC1 (legacy)	L3.5 IT/OT Boundary	AP9617, AP9618, AP9619	hw02 family, AOS proprietary RTOS, FTP-based unsigned firmware upgrade (<code>upgrd_util.exe</code> + <code>winftp32.dll</code>), pre-TLStorm signing era	8 files (3 firmware payloads + upgrade tooling)
F. Smart-UPS internal MCU	Power Infrastructure (L0/L1-adjacent)	SRT5KRMXLI, SRT5KXLT, SRT5KRMXLT30, SRT3000RMXLI, SRT8KXLI, SRT10KXLI, SRTL3K/5K/6KRMXLI (Lilion), SMT1500RM2UC, SMC1500, SMX/XU/XP	APC proprietary Cadillac/CBL chipset; <code>.enc</code> signed payload post-CVE-2022-0715, raw <code>.bin</code> prefix; Cadillac CBL <code>.img</code> updater is binwalk-opaque	20,369 rows (Smart-UPS Wizard)

Group A — NMC3 AP964x (signed firmware, modern stack) — Purdue L3.5 (IT/OT Boundary)

Direct attack surface (verified via signed-image header + embedded web UI strings in the extracted AP964x firmware):

HTTPS (TLS 1.2/1.3) • SSHv2 • SNMPv3 (v1/v2c disabled by default in 2.x) • Modbus TCP/502 (opt-in) •
RADIUS client • Syslog client • NTP client • FTP DISABLED by default • Trusted-Platform signed boot

The signed-image manifest shows ECDSA-P256 over the firmware payload; downgrade to unsigned NMC2-era images is rejected by the bootloader. SNMPv1/v2c and Telnet are present in the binary but ship disabled.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status on the firmware you have
CVE-2022-22805	9.0	NMC2/NMC3 TLS reassembly	Memory-corruption RCE pre-auth via crafted TLS packets ("TLStorm" #1)	Fixed in NMC3 ≥ 1.1.0.16 — verify your catalog floor
CVE-2022-22806	9.0	NMC2/NMC3 TLS state-confusion	Auth bypass during TLS handshake ("TLStorm" #2)	Same — confirm catalog hashes map to patched build
Schneider PSIRT — Easergy / Galaxy mgmt-iface class	—	Schneider mgmt-plane Java-RMI bug class	Missing-auth on critical methods — same Java-RMI exposure pattern PowerChute mgmt agents have historically shared	Schneider PSIRT portal — research only

Top attack vector (MITRE ATT&CK ICS): [T0857 System Firmware](#) — even with signed firmware, the TLStorm class showed that the TLS *parser* is the pre-auth attack surface; firmware signing protects the flash path, not the live network parser.

Group B — NMC2 AP963x (the TLStorm legacy) — Purdue L3.5 (IT/OT Boundary)

Direct attack surface (verified via embedded strings + cgi-bin paths in extracted AP963x firmware):

HTTPS (older OpenSSL/Mocana NanoSSL) • SSHv1/v2 • Telnet (default enabled on pre-6.0.6) •
FTP (default enabled pre-6.x — used as firmware-upload channel) • SNMPv1/v2c (community public/private) •
Modbus TCP/502 • BACnet/IP UDP/47808 (opt-in) • web UI superuser `apc`/`apc`

Default `apc / apc` credentials are baked into factory state. FTP-based firmware push (`nmc_*.bin` over FTP) is the historical update path — no signature enforcement on AP963x below firmware 6.8.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status on the firmware you have
CVE-2022-22805	9.0	NMC2 (Mocana NanoSSL packet-reassembly)	Pre-auth RCE via crafted TLS — TLStorm #1, Armis writeup	Fixed in NMC2 ≥ 6.9.6 — anything older in your 85-hash catalog is vulnerable
CVE-2022-22806	9.0	NMC2 TLS state-confusion	Auth bypass — TLStorm #2	Same fix line — verify
CVE-2022-0715	8.9	NMC2/NMC3 firmware-upgrade signature check	Unsigned firmware accepted → arbitrary code persistence ("TLStorm" #3)	The reason AP963x ≤ 6.7 cannot trust its own flash path
CISA ICSA-22-083-01	—	APC Smart-UPS family (TLStorm bundle)	Authoritative advisory bundling the three TLStorm CVEs	Reference

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) (TLStorm pre-auth on TLS) chained into [T0857 System Firmware](#) (CVE-2022-0715 lets the post-RCE payload survive reboot as legitimate firmware).

Group C — Rack PDU 2G AP86xx — Purdue L3.5 (IT/OT Boundary) with L1 outlet-actuation

The 71-hash AP86xx catalog is an NMC variant retargeted for switched/metered PDU outlet control. Stack is the same family as NMC2/NMC3, so the *same* TLStorm CVE class applies depending on which generation the AP86xx unit shipped with.

Direct attack surface (verified via extracted AP86xx firmware strings):

```
HTTPS/SSH/SNMPv3 web UI · per-outlet ON/OFF/CYCLE control endpoints · SNMP `epdu` MIB  
(rPDU2OutletSwitchedControlCommand, rPDU2OutletSwitchedConfigPowerOnDelay)
```

Attack vectors:

- **Outlet-control via SNMP** `set` to `rPDU2OutletSwitchedControlCommand` — set value=2 (outletOff) is the destructive single-OID write. SNMPv1/v2c with default community here = single-packet

rack power-off.

- **TLStorm parser bug** is the same Mocana stack — AP86xx firmware predating the 2022 fix line is RCE-exploitable.
- **Mass-PDU coordinated outlet shutdown** as an availability/destructive ICS attack — explicitly modeled by CISA in the 2022 internet-exposed-UPS advisory.

Top attack vector (MITRE ATT&CK ICS): [T0879 Damage to Property](#) via [T0855 Unauthorized Command Message](#) — single SNMP write disables an entire rack.

Group D — PowerChute / EcoStruxure IT (Windows-side) — Purdue L3 (Site Operations) with L4 corp-IT + L4/L5 cloud edges

CVE	CVSS	Product	Vector
CVE-2021-22812	9.8	PowerChute Business Edition (Schneider FA433580 — EOL)	Unauth RCE via deserialization in management agent
CVE-2021-22813	7.5	PowerChute Business Edition (EOL)	Auth bypass on local web mgmt
Schneider PSIRT — PowerChute Serial Shutdown local-privesc class	7.x	PowerChute Serial Shutdown (PCSS)	Local privilege escalation via insecure directory / service-permissions class — see Schneider PSIRT portal
Schneider PSIRT — EcoStruxure IT Gateway mgmt-plane class	7.x	EcoStruxure IT Gateway	Auth/management-plane vuln class — see Schneider PSIRT portal

The PCSS installer extraction now yields a 4,083-row catalog — Sysmon image-load / file-create rules can match against this hash set to detect tampered PCSS components on admin hosts. PowerChute Business Edition (Schneider FA433580) is EOL but still installed in long-tail environments; treat its presence on any admin host as a footholdable surface for CVE-2021-22812 / -22813.

If a Windows admin host runs PowerChute / EcoStruxure IT below the current PSIRT-fixed build, that host is the foothold path to every AP963x/AP964x/AP86xx it manages — and via the legitimate PCSS / wizard flash channel, to every Smart-UPS internal MCU (Group F) it serves.

Group E — NMC1 AP961x (legacy NMC, pre-TLStorm signing era) — Purdue L3.5 (IT/OT Boundary)

The 8-file NMC1 catalog covers AP9617 / AP9618 / AP9619 — the original hw02-family management cards that pre-date the signed-firmware regime entirely. The catalog includes the three firmware payloads (`apc_hw02_aos_202.bin`, `apc_hw02_aos_394.bin`, `apc_hw02_sumx_393.bin` — AOS 2.0.2, AOS 3.9.4, and the SUMX 3.9.3 UPS application module) plus the FTP-based upgrade tooling (`upgrd_util.exe`, `winftp32.dll`, `config.txt`, `go.bat`, `iplist.txt`). These cards run an APC proprietary AOS RTOS — there is no embedded Linux, no ECDSA signing, no Trusted Platform boot. They are directly analogous to [Eaton brief Group C](#) (Legacy NMC NmckA / inmc family).

Direct attack surface (verified via extracted hw02 payload + upgrade-utility strings):

```
Telnet (default enabled) · HTTP (no TLS, web UI on port 80) · FTP (default enabled – firmware upload channel) ·  
SNMPv1/v2c (community public/private) · default `apc`/`apc` web UI superuser · no firmware signing
```

Attack vectors:

- **Unsigned FTP firmware push.** `upgrd_util.exe` drives `winftp32.dll` to PUT the raw `apc_hw02_*.bin` payload over FTP. There is no signature check on the card — any `.bin` of the right header shape is accepted as legitimate firmware. This is the pre-CVE-2022-0715 baseline behavior: the bug class doesn't need a CVE because there is no signing to bypass.
- **SNMPv1 default communities + Telnet/HTTP cleartext.** Credentials and config writes traverse the wire in plaintext; sniff anywhere on the management LAN.
- **Cannot be patched to a signed-firmware state.** Latest AOS for hw02 is 3.9.4 / SUMX 3.9.3 — APC never backported signed-firmware support to NMC1. The only defense is network isolation and detection.

Top attack vector (MITRE ATT&CK ICS): [T0857 System Firmware](#) via unauthenticated FTP push — no exploit chain required, the upgrade path *itself* is the persistence mechanism. Chains naturally with [T0812 Default Credentials](#) for the first hop.

Group F — Smart-UPS internal MCU (Cadillac/CBL bare-metal) — Power Infrastructure (L0/L1-adjacent)

The 20,369-row Smart-UPS Wizard extraction is the bare-metal UPS controller firmware for the Smart-UPS Online SRT, SRTL Li-Ion, SMT, SMC, SMX, XU, and XP families. Products in scope: SRT5KRMXLI, SRT5KXLT, SRT5KRMXLT30, SRT3000RMXLI, SRT8KXLI, SRT10KXLI, SRTL3KRMXLI / SRTL5KRMXLI / SRTL6KRMXLI (Lithium-Ion), SMT1500RM2UC, SMC1500, and the SMX/XU/XP series. The wizard ships `.enc` signed payloads (post-CVE-2022-0715 fix), raw `.bin` payloads (pre-fix builds

still found in the wild), the Cadillac CBL `.img` updater (binwalk-opaque proprietary blob — track as a single SHA-256), the wizard executable itself, and supporting tooling. There is **no IP attack surface on the UPS itself** — it reaches the network only via a connected NMC card or via USB/serial to a Windows host running the wizard.

Attack vectors:

- 1. **CVE-2022-0715 (TLStorm #3) — firmware-upgrade signature-check bypass on the internal MCU.** This is *exactly* the Group F surface. Pre-fix Cadillac/CBL firmware accepts arbitrary `.bin` payloads as legitimate — the post-fix `.enc` format is the signed mitigation. The 20,369-row catalog now makes this a hash-matchable check: every `.bin` / `.enc` payload pushed via the wizard or PCSS flash channel can be SHA-256-matched against the wizard-shipped hash set.
- 2. **Serial/USB console (DB9/USB-B).** Direct register access on the Cadillac/CBL board if the attacker is local to the UPS — bypasses the NMC entirely.
- 3. **Firmware tamper via the Windows admin host that runs the Smart-UPS Wizard / PCSS.** The wizard authenticates nothing on its own host beyond Windows ACLs — compromise the admin host (Group D vector) and push tampered firmware via the normal flash path.
- 4. **Battery-management parameter abuse — particularly dangerous on the SRTL Li-Ion line (SRTL3K/5K/6KRMXLI).** Thermal-runaway risk if BMS protection thresholds are altered via tampered firmware.
- 5. **Cadillac CBL `.img` updater is proprietary and binwalk-opaque.** No further extraction is meaningful — track it as a single SHA-256 in the Group F catalog. Any divergence from the wizard-shipped hash is tampering.

Top attack vector (MITRE ATT&CK ICS): [T0857 System Firmware](#) via CVE-2022-0715 on pre-fix builds, chained back from a Group D Windows-side foothold (T1574 hijack on PCSS/wizard host → [T0830](#) adversary-in-the-middle on the flash channel).

Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	NMC syslog (UDP/514)	User logged in followed within 60s of repeated Authentication failed	Brute-force success on <code>apc</code> / <code>apc</code> or rotated creds	T0812 Default Credentials

#	Source	Event	What it catches	MITRE ATT&CK ICS
2	NMC syslog	Firmware updated outside change-window OR firmware version <i>downgrade</i>	TLStorm-class persistence (CVE-2022-0715)	T0857 System Firmware
3	NMC syslog	Configuration changed + User created + SNMP community modified within 5 min	Persistence + parameter modification	T0836 Modify Parameter
4	Network IDS (Suricata/Zeek)	SNMP Set-Request to rPDU20outletSwitchedControlCommand from non-mgmt-VLAN source	Direct outlet-off attack on AP86xx	T0855 Unauthorized Command Message
5	Network IDS	TLS handshake to NMC IP with abnormal record length / fragmented ClientHello	TLStorm CVE-2022-22805/22806 exploit traffic	T0866 Exploitation of Remote Services
6	Network IDS	Modbus function codes 5/6/15/16 crossing mgmt→OT boundary toward NMC	Control-logic tamper	T0833 Modify Control Logic
7	Sysmon on PowerChute / Smart-UPS Wizard hosts	EventID 1 where ParentImage= PowerChute*.exe / *Wizard*.exe / upgrd_util.exe AND child is cmd.exe / powershell.exe / rundll32.exe ; or EventID 7 ImageLoad of non-APC DLLs by these processes	CVE-2021-22812 deserialization post-ex; T1574 hijack on flash tooling	T1574 / T1059 (Enterprise)
8	Sysmon	EventID 11 (FileCreate) of nmc_*.bin / apc_hw*.bin / Smart-UPS *.enc / *.img on PowerChute / wizard / admin host outside maintenance	Staged tampered firmware ready to push (NMC1/2/3 or Group F MCU)	T0857 System Firmware

Secondary:

- Firewall: any egress from NMC/PDU VLANs to non-RFC1918 — APC NMCs should never originate outbound to the internet; the 2022 CISA UPS advisory called this out as the primary internet-exposure path.
- NMC native audit log: enable `Logs → Config → Audit Log` and forward via syslog. Categories: `Auth`, `Config`, `System`, `Event`. NMC3 also emits `Trusted Platform` boot-failure events — pipe those. NMC1 hw02 cards have only a minimal event log; rely on network IDS for those.
- SNMP trap collector: subscribe to `upsBasicTrapsOnBattery`, `upsAdvBatteryReplaceIndicator`, `rPDU20outletSwitchedStatusState`. Correlate sudden battery-test or outlet-off events with maintenance windows.

- OT-native: load drop >30% on a UPS with no scheduled change → possible `outlet off` SNMP/BACnet write; output frequency drift > $\pm 0.5\text{Hz}$ → control-loop tampering precursor; unexpected BMS-threshold or charge-profile change on SRTL Li-Ion → Group F firmware-tamper precursor.
- Hash matching: SHA-256 every `.bin / .enc / .img` observed on PCSS/wizard hosts (EventID 11 above) against the 20,369-row Group F catalog and the 8-file Group E catalog. Mismatch = tampered payload staged for flash.

Specific zero-day-ish concerns for your dataset

1. **TLStorm catalog-floor check — now extends to Group F.** Of the 85 NMC2 and 82 NMC3 hashes extracted, anything predating NMC2 6.9.6 / NMC3 1.1.0.16 is exploitable by CVE-2022-22805/22806/0715. Map every hash to its embedded firmware-version string and flag anything below those floors — TLStorm is a *single packet* pre-auth chain. **Group F now has 20,369 Smart-UPS Wizard hashes to match against**, so CVE-2022-0715's flash-channel signature-bypass surface is finally hash-checkable: any raw `.bin` payload (vs. the post-fix `.enc` format) staged on an admin host = pre-fix Cadillac/CBL build vulnerable to TLStorm #3.
2. **AP86xx outlet-control SNMP exposure.** A single SNMP `set` to `rPDU20outletSwitchedControlCommand` with value=2 powers off a rack. AP86xx units shipped historically with SNMPv1 `private` write community enabled. Audit your 71-hash AP86xx catalog for default-community config blocks (string `private` in the SNMP config region).
3. **Signed-firmware ≠ signed-parser.** Even fully-patched NMC3 AP964x firmware is still a network parser exposed to untrusted TLS bytes. TLStorm proved the *parser* is the surface; treat any pre-auth crash signal from a Suricata `tls-anomalous-record-length` rule as a real CVE-class event, not a benign scanner.
4. **PowerChute / Smart-UPS Wizard as the lateral path.** PowerChute and wizard hosts hold credentials/TLS trust to every NMC they manage, plus direct flash-channel access to every Smart-UPS internal MCU they serve. CVE-2021-22812 deserialization on PowerChute Business Edition → push tampered NMC firmware (Groups A/B/C/E) via the legitimate update channel → CVE-2022-0715-style persistence on every card, and via the wizard flash channel → tampered Cadillac/CBL payload on every Smart-UPS (Group F).
5. **NMC1 hw02 cannot be patched to a signed-firmware state.** The 8-file Group E catalog represents the highest-trust deployable firmware APC ever shipped for AP9617/18/19 — and it still has no signing, no TLS, and default `apc / apc`. Treat any AP961x card on a routable LAN as already compromised for threat-modeling purposes; isolation is the only mitigation.

6. **Cadillac CBL  updater is binwalk-opaque.** Do not chase further extraction — track the single SHA-256 from the Smart-UPS Wizard distribution. Any divergence from the wizard-shipped hash on an admin host = tampering, full stop. This is the cheapest high-signal detection in the entire Group F surface.
-

Sources

- [CISA — Mitigating Attacks Against UPS Devices \(2022\)](#)
- [CISA ICSA-22-083-01 — APC Smart-UPS \(TLStorm\)](#)
- [Armis — TLStorm research \(3 zero-days in APC Smart-UPS\)](#)
- [Schneider Electric Cybersecurity Support Portal / PSIRT](#)
- [Schneider PSIRT — Security Notifications index](#)
- [NVD — CVE-2022-22805](#)
- [NVD — CVE-2022-22806](#)
- [NVD — CVE-2022-0715](#)
- [NVD — CVE-2021-22812 \(PowerChute Business\)](#)
- [NVD — CVE-2021-22813 \(PowerChute Business\)](#)
- [APC NMC Security Handbook \(default creds + hardening\)](#)
- [MITRE ATT&CK for ICS — T0857 System Firmware](#)
- [MITRE ATT&CK for ICS — T0855 Unauthorized Command Message](#)
- [MITRE ATT&CK for ICS — T0866 Exploitation of Remote Services](#)
- [MITRE ATT&CK for ICS — T0812 Default Credentials](#)
- [MITRE ATT&CK for ICS — T0836 Modify Parameter](#)
- [MITRE ATT&CK for ICS — T0833 Modify Control Logic](#)
- [MITRE ATT&CK for ICS — T0830 Adversary-in-the-Middle](#)
- [MITRE ATT&CK for ICS — T0879 Damage to Property](#)
- [MITRE ATT&CK Enterprise — T1574 Hijack Execution Flow](#)
- [MITRE ATT&CK Enterprise — T1059 Command and Scripting Interpreter](#)
- [Forescout 2025 OT Threat Report — power-infrastructure targeting trends](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)